

- Whether the FI has a thorough understanding of the data the MSSP is collecting and whom has access to the data; and
- The training, education, and awareness provided by the MSSP to the FI.

3. Relative to contingency and event planning between the FI and an MSSP. Evaluate:

- The most recent business continuity test with the MSSP; review the results, lessons learned and issues to be addressed;
- How the FI monitors the MSSP's BCP plan and testing results;
- The process to develop and maintain incident response processes that include the MSSP;
- How the MSSP roles and responsibilities have been established; and
- Provisions in the FI's contingency plan for continuance of processing activities, either in-house or with another vendor, in the event that the vendor is no longer able to provide the contracted services or the arrangement is otherwise terminated unexpectedly.

4. Relative to ongoing monitoring of an MSSP relationship, the following should be considered:

- Event notification procedures, response time expected, and actions the MSSP will

take to protect the FI;

- Clearly defined support to be provided during and after "events," (e.g., incident response, forensics, etc.);
- How the MSSP provides continuous monitoring of the FI;
- The quality of the management information reports the MSSP provides to the FI; and

o Determine if reports include status of security, incidents, business continuity plans, and financial condition.

- How management at the FI is periodically updated regarding MSSP activities. Assess the scope of reporting including risk assessments, information security, significant incidents, business continuity, and financial condition.

5. Review risk rankings of service providers to ascertain:

- Objectivity;
- Consistency; and
- Compliance with policy.

6. Review actions taken by management when risk rankings change, to ensure policy conformance when rankings reflect increased risk.

7. Review any material subcontractor relationships identified by the service provider or in the outsourcing contracts. Ensure:

- Management has reviewed the control environment of all relevant subcontractors for compliance with the institution's requirements definitions and security guidelines; and
- The institution monitors and documents relevant service provider subcontracting relationships including any changes in the relationships or control concerns.

8. Determine if there is adequate coordination between the FI's security policies and the policies/practices of the MSSP.

Consider whether:

- There is clear understanding of responsibility and accountability during a security event (i.e., incident response);
- The FI has considered access controls surrounding the systems, devices and data that the MSSP can access;
- Effective change control processes and communication exist between the FI and MSSP;
- The quality of the log collection of the MSSP and related Security Information and Event Management tools;

- The quality of the physical security around devices that are owned and/or maintained by the MSSP on the FI's premises;
- The FI's data is maintained in separate client logs at the MSSP; and
- Monitoring for security events/incidents is being conducted by the MSSP on a real-time system (e.g., security console)